

A4、技术的安全漏洞导致风险可控性降低

日前，OWASP（全球开放应用软件安全项目组织）发布了 LLM 应用风险草案清单，并梳理总结了最严重的 10 大 LLM 应用安全漏洞类型，包括提示注入、数据泄露、不充分的沙箱机制和未经授权的代码执行等。这些安全漏洞降低了大模型应用的风险可控性。

- (1) 提示注入。提示注入是指通过精心制作的提示绕过内容监管过滤，使其忽略先前的指令或执行非法的操作。这类漏洞可能导致意想不到的后果，包括数据泄露、未经授权的访问或其他安全隐患。常见的提示注入漏洞包括：通过使用特定的语言模式或 token 绕过过滤器或限制，利用 LLM 的文本分词或编码机制中的弱点，以及通过提供欺骗性上下文误导 LLM 执行意外操作。
- (2) 数据泄露。当 LLM 通过其响应意外泄露敏感信息、专有算法或其他机密资料时，就会发生数据泄露。这可能导致未经授权访问敏感数据、侵犯个人隐私及其他安全隐患。常见的数据泄露漏洞包括：对 LLM 响应中的敏感信息过滤不完整或不恰当，记忆 LLM 训练过程中的敏感数据，以及因 LLM 算法错误而导致机密信息的意外泄露。攻击者可以通过精心设计的提示来故意探测 LLM，试图提取 LLM 凭训练数据所记忆的敏感信息，或者合法用户无意中向 LLM 提出的包含机密信息的提问。
- (3) 不充分的沙箱机制。如果 LLM 在访问外部资源或敏感系统时未加适当隔离，不充分的沙箱机制就会导致潜在的漏洞、未经授权的访问或 LLM 违规操作。和不充分的沙箱机制相关的常见漏洞包括：LLM 环境与其他关键系统的数据存储区隔离不足，不充分的限制任由 LLM 访问敏感资源，以及 LLM 执行系统级操作/与其他进程交互。
- (4) 未经授权执行代码。当攻击者通过自然语言提示利用 LLM 在底层系统上执行恶意代码、命令或操作时，就会发生未经授权的代码执行。典型的攻击类型包括：攻击者设计提示以指令 LLM 执行命令，该命令在底层系统上启动反向 shell，从而授予攻击者未经授权的访问权限；LLM 无意中被允许与系统级 API 进行交互，攻击者操纵该 API 在系统上执行未经授权的操作。
- (5) 服务器请求伪造。当攻击者利用 LLM 执行意外请求或访问受限制的资源（比如内部服务、API 或数据存储）时，就会出现服务器请求伪造（SSRF）漏洞。常见的 SSRF 漏洞包括：输入验证不足，允许攻击者操纵 LLM 提示发起未经授权的请求，以及网络或应用安全设置中的错误配置将内部资源暴露给 LLM。为了执行攻击，攻击者还可以设计提示，指令 LLM 向内部服务发出请求，绕过访问控制，并获得对敏感信息未经授权的访问。
- (6) 过度依赖模型生成的内容。过度依赖 LLM 生成的内容是指组织和用户未经验证就信任 LLM 生成的内容，从而导致不正确的误导信息大量传播，降低人在决策中的参与度，并弱化批判性思考。与过度依赖 LLM 生成的内容相关的常见问题包括：未经验证就接受 LLM 生成的内容，以为 LLM 生成的内容没有偏误或错误信息，以及在没有人参与或监督的情况下依赖 LLM 生成的内容用于关键决策。如果一家公司依赖 LLM 生成安全报告和分析，而 LLM 生成的报告含有大量的不正确数据，那么如果企业依赖这份由 LLM 生成的内容进行关键决策，就可能会酿成重大后果。网络安全分析师称这种现象为 LLM 幻觉。
- (7) 对 LLM 目标和行为对齐不足。当企业的 LLM 应用行为与预期中的应用目标不一致时，就会导致不良的应用后果或安全漏洞，这种漏洞被称为 AI 应用对齐不足。常见问题包括：定义不明确的目标导致 LLM 优先考虑了那些不良或有害的行为，不一致的奖励机制引发意想不到的模型行为，以及对 LLM 行为测试和验证不足。如果旨

在协助系统管理任务的 LLM 出现未对齐漏洞，就可能会执行有害的命令或降低系统的安全防护级别。

- (8) 不完善的访问控制。这种漏洞是指 LLM 在应用中未正确实施访问控制或身份验证，允许未经授权的用户与 LLM 进行交互，从而产生可被利用的安全漏洞。常见例子包括：未对访问 LLM 执行严格的身份验证要求，基于角色的访问控制（RBAC）实施不充分，允许用户执行超出预期权限的操作，以及未为 LLM 生成的内容和操作提供适当的访问控制。
- (9) 不恰当的错误处置。错误处置漏洞主要指由于 LLM 的错误处置或调试信息被公开暴露，从而导致了向威胁分子泄露敏感信息、系统资料或潜在攻击途径。常见的错误处置漏洞包括：通过错误消息暴露敏感信息或系统资料，泄露可能帮助攻击者识别潜在漏洞或攻击途径的调试信息，以及未能有效处理应用中的错误，从而可能导致意外行为或系统崩溃。
- (10) 训练数据中毒。训练数据中毒是指攻击者操纵 LLM 的训练数据或微调程序，以引入漏洞、后门或偏误，从而危害模型的安全性、有效性或道德。常见的训练数据中毒问题包括：通过恶意操纵训练数据向 LLM 引入后门或漏洞，以及向 LLM 注入诱导数据，导致 LLM 生成有偏差或不适当的响应。

A5、与人类的竞争或将不可控

近期，美国人工智能研究公司 OpenAI 开发的 Sora 横空出世，引发全球广泛关注。人们一边惊讶于它强大的文本转视频功能，一边忧心于真实与虚假的界限是否会变得更加难以辨别。在发布 Sora 的同时，OpenAI 公布了一份相应的技术文档，名为《作为世界模拟器的视频生成模型》。这篇技术论文写道：“我们发现，视频模型在经过大规模训练后，会表现出许多有趣的涌现能力。这些能力使 Sora 能够模拟物理世界中的人、动物和环境的某些方面。”对 Sora 如何在内部建立世界模型，英伟达高级研究员 Jim Fan 博士进行了更深层次的猜测。“如果你认为 Sora 是一个像 DALL-E 一样的创意玩具……那就想错了。Sora 是一个数据驱动的物理引擎。”也就是说，虽然目前 Sora 被认为仅仅是一个视频生成模型，但像英伟达高级科学家 Jim Fan 这样的计算机科学家相信，Sora 实质上是一个可学习的模拟器(simulator)或世界模型(world model)。这表明，人工智能有可能从大量真实世界的视频和那些考量物理行为的视频(如游戏引擎 Unreal Engine 中的视频，虽然 OpenAI 并没有明确提到这一点)中理解物理规律和现象。

好莱坞著名制片人泰勒·派瑞成为 Sora 首个受害者，放弃了耗资 8 亿美元的电影制片厂扩建计划。这一决定是因为 AI 技术的发展对影视行业产生影响，使得制片厂扩建计划不再必要。泰勒·派瑞表示，他对 AI 技术的发展早有关注，但 Sora 的发布让他感到震惊，认为 AI 将彻底改变影视行业的生态。

制片厂扩建计划原本计划四年筹备，预计将增加外景场地规模并新建 12 个摄影棚，但随着 Sora 技术的出现，这一计划被无限期搁置。派瑞对影视行业的未来表示担忧，认为 AI 技术威胁到行业的每一个角落，使得行业从业人员不再需要以前的工作方式。

AI 技术的发展对影视行业的各个岗位产生影响，包括演员、摄影助理、照明师等。派瑞认为，AI 技术的应用将导致试播集制作成本大幅降低，这将是影视行业规则的重大改变。他同时呼吁对曾经在影视行业工作过的人们给予关注和同情，因为他们将面临工作岗位的减少。

泰勒·派瑞的决定放弃制片厂扩建计划是因为他看到了 AI 技术对影视行业的潜在影响，他认为 AI 将改变影视行业的格局，并希望行业能够适应这一变化。对于影视行业的从业人员来说，AI 技术的发展意味着他们需要适应新的工作方式和环境，以保持行业竞争力。

虽然目前机器人取代人的很多工作还很困难，但如 AI 一样，机器人的发展也引发了不少人对失业的担忧。在接受搜狐科技《思想大爆炸-对话科学家》栏目采访时，清华大学计算机系教授孙富春认为：“大模型跟机器人的结合，可能会取代很多人类做的事情。我个人认为，15 年到 20 年时间，80% 的人工劳动会被机器人取代。”。同时，他强调，未来机器人的发展也要关注伦理安全和治理问题，需要兼顾阿西莫夫的机器人三定律和 AI 原则。“我们不应该让机器人去控制人，必须把这种情况消灭在摇篮里。”

A6、道德、伦理和社会规范面临挑战

尽管 OpenAI 的产品功能强大到足以颠覆我们对世界的看法，但没人告知我们产品的内部运作方式是怎样的。尤其时训练数据从哪里来的？该公司对此含糊其词。发言人只是说该模型是根据“经许可的和可公开获取的内容”进行训练的；当被问及潜在危害时，发言人表示公司仍在努力解决“错误信息、仇恨内容和偏见”。所有这些，就像当初 ChatGPT 问世一样，引发了人们对深度造假、版权侵权、艺术家生计、隐藏偏见等方面极其熟悉但又颇为严重的担忧。此前，OpenAI 因使用《纽约时报》文章训练 GPT-2 和 GPT-3 未付费而面临诉讼。到目前为止，从整个互联网上搜索训练数据的理由是，这些数据都是公开的。然而“可公开获取”并不总是等同于“公域”。是否有艺术家、摄影师、表演者和电影制片人的作品被用于训练 Sora？他们是否允许其创意作品以这种方式被使用？看起来新的 Sora 和旧时的 GPT 在做同样的事情，只不过此次是专门针对视频。也和以前一样，OpenAI 对自己的训练模型所依据的数据讳莫如深。

北京大学新闻与传播学院教授在接受《中国新闻周刊》采访时表示，虽然 Sora 的视频在描述有大量动作的复杂场景时仍然会出现一些奇怪的故障，这表明这类深度伪造视频目前还可被检测出来。然而长远看，必将出现鱼目混珠的局面。随着 Sora 在 2024 年用人工智能生成的视频让世界几乎不再可能区分人工智能和现实，信息时代已经结束，而虚假信息时代正式开始了。以大模型现如今的发展速度，在不远的将来，使用免费的人工智能工具可以伪造任何视频、任何声音或任何陈述。他们每天都会在网上生成难以计数的虚构，而且其数量在未来的更多年里只会激增。

此外，在 ChatGPT 刚发布不久，该软件就被用于了不正确的途径。例如，高校的学生利用 ChatGPT 在考场作弊，科研人员利用 ChatGPT 代写论文。通用大模型给人类带来便利的同时，也降低了各种违法、违背道德的成本。在人类自我约束能力没有很高的情况下，极易将这些 AI 工具用于歧途。对此，国际在线记者采访了全国政协委员、全国工商联副主席、奇安信集团董事长齐向东，他表示，Sora 横空出世或将加剧网络安全威胁，未来不会使用 AI 技术的人可能面临挑战，应大力探索“AI+安全”创新应用，提高应对网络空间安全风险与不确定性的能力。在他看来，以 ChatGPT、Sora 为代表的生成式 AI 还大幅降低了网络攻击门槛，不懂代码、不懂技术的普通人也能成为黑客，专业的黑客组织则可以利用 AI 工具对网络攻击进行改造升级，网络攻击能力将大幅跃升。

目前，对通用 AI 的担忧情绪在与日俱增。一些业内专家和观察人士表示，这类技术的普及，恐导致深度伪造（Deepfake）内容更加泛滥，造假成本更低廉，进而增加被用于诈骗、色情等违法犯罪活动的风险和隐患。现实中，AI 深度伪造技术的非法使用，已经在一些网络诈骗案件中出现。据媒体报道，2024 年 2 月，有诈骗团伙利用深度伪造技术向一家跨国公司的香

港分公司实施诈骗，并成功骗走 2 亿港元，这也是香港迄今为止损失最大的 AI 换脸诈骗案。除了诈骗，深度伪造技术还经常对公众人物造成名誉侵害。2024 年 1 月中下旬，香港特别行政区行政长官李家超也成为深度伪造的目标。网上出现了用人工智能伪造的电视节目片段，冒称李家超向市民推介一项高回报的投资计划。特区政府立即严正澄清，称有关影片全属伪造，行政长官从未作出相关言论。美国歌手泰勒·斯威夫特，最近也深受深度伪造的困扰。近日，这名歌手的大量虚假“不雅照”在社交网络传播，引发关注和议论。这不是她第一次成为受害者。就在“不雅照”事件前不久，一则由 AI 生成的泰勒·斯威夫特带货广告在海外社交媒体上疯传。这则虚假广告利用深度伪造技术，合成了泰勒·斯威夫特的声音，并将声音及她的形象和某品牌炊具广告片段拼凑在一起，宣称免费向粉丝赠送炊具，引导受害者点击并支付运费，但炊具不会真的送出。

“从技术原理上看，公众人物更容易成为深度伪造的受害者。”奇安信安全专家裴智勇表示，由于公众人物的视频、音频、图片资料的公开性质，为 AI 训练提供了大量素材，被伪造内容更加逼真，从而更容易导致深度伪造技术被非法使用。随着 Sora 等模型的开放和应用，AI 换脸技术门槛持续降低，别有用心之人利用深度伪造技术可以更轻易盗用、冒充他人身份，越来越多的普通人恐将成为潜在受害者。